

Project Task-3

Vulnerability Assessment

Report

Target: OWASP Juice Shop (192.168.161.132)

Prepared by: Venkat Rajesh

Environment: Kali Linux + Ubuntu (VMware
Fusion)

Vulnerability Assessment Report

Executive Summary

The purpose of this vulnerability assessment was to evaluate the security posture of an intentionally vulnerable web application, **OWASP Juice Shop**, deployed within a controlled laboratory environment. The assessment was conducted using industry-standard security tools including **Nmap**, **Nikto**, and **Dirsearch** to identify exposed services, accessible resources, and common web application security weaknesses.

The assessment followed a structured methodology beginning with network reconnaissance, followed by service enumeration and web application scanning. No exploitation or destructive testing was performed during this assessment, ensuring that the target environment remained stable throughout the testing process.

The findings indicate that the target application exposes a web service on TCP port **3000** and contains several security weaknesses commonly found in vulnerable web applications. These include missing HTTP security headers, publicly accessible resources, and discoverable API endpoints. Since OWASP Juice Shop is intentionally designed as a training platform, these findings are expected and provide an excellent environment for learning vulnerability assessment techniques.

This report documents the methodology, tools used, findings, risk ratings, impact analysis, and recommended remediation measures to improve the security posture of similar web applications deployed in production environments.

Objectives

The primary objectives of this vulnerability assessment were to:

- Identify whether the target system is reachable over the network.
- Discover open ports and identify the services running on those ports.
- Determine service versions and gather information through service enumeration.
- Identify common web server and web application security weaknesses.
- Discover hidden directories, files, and exposed API endpoints.
- Assess the overall security posture of the target application.
- Provide practical remediation recommendations based on the findings.
- Gain hands-on experience with industry-standard vulnerability assessment tools and methodologies.

Scope

In Scope

The following systems and activities were included in this assessment:

- Target Virtual Machine running Ubuntu Linux
- OWASP Juice Shop web application
- Network reconnaissance
- Port scanning
- Service enumeration
- Web server assessment
- Directory and endpoint enumeration
- Non-destructive vulnerability assessment

Target IP Address:

192.168.161.132

Assessment Environment:

- VMware Fusion

- Kali Linux (Attacker Machine)
- Ubuntu Linux (Target Machine)
- Docker Container hosting OWASP Juice Shop

Out of Scope

The following activities were intentionally excluded:

- Vulnerability exploitation
- Privilege escalation
- Denial-of-Service (DoS) attacks
- Password cracking
- Brute-force attacks
- Malware deployment
- Testing systems outside the controlled laboratory
- Any activity that could damage or disrupt the target environment

Methodology

The assessment followed a structured vulnerability assessment workflow like that used by cybersecurity professionals.

Phase 1 – Network Reconnaissance

The assessment began by identifying the IP address of the target machine and verifying network connectivity between the Kali Linux attacker machine and the Ubuntu target using ICMP ping requests.

Phase 2 – Port Scanning

A basic TCP port scan was performed using Nmap to determine which services were exposed to the network.

Phase 3 – Service Enumeration

Nmap Service Detection (-sC -sV) was used to identify running services, collect service banners, determine HTTP response headers, and gather additional information about the application.

Phase 4 – Aggressive Scanning

An aggressive Nmap scan (-A) was performed to collect operating system information, execute default NSE scripts, and identify additional characteristics of the target system.

Phase 5 – Web Server Assessment

Nikto was used to scan the web server for common misconfigurations, missing security headers, sensitive files, and potentially insecure resources.

Phase 6 – Content Discovery

Dirsearch was executed to enumerate hidden directories, API endpoints, and publicly accessible resources that could increase the application's attack surface.

Phase 7 – Risk Assessment

The identified findings were categorized according to their potential impact on confidentiality, integrity, and availability, and appropriate remediation recommendations were documented.

Tools Used:

Tool	Purpose
Nmap	Host discovery, port scanning, service enumeration, operating system detection
Nikto	Web server vulnerability assessment and misconfiguration detection
Dirsearch	Directory and file enumeration
Docker	Hosting the OWASP Juice Shop application
VMware Fusion	Virtualized laboratory environment
Kali Linux	Attacker machine
Ubuntu Linux	Target machine

Technical Findings

Finding 1 – Open Web Service on Port 3000

The Nmap scan identified TCP port **3000** as open and accessible. The service responded with HTTP traffic and was identified as the OWASP Juice Shop application.

Risk Level: Medium

Evidence

- Port 3000/TCP Open
- HTTP Response Received
- OWASP Juice Shop Identified

Impact

An exposed web service increases the attack surface and provides potential entry points for attackers if vulnerabilities exist within the application.

Finding 2 – Missing HTTP Security Headers

Nikto identified several recommended HTTP security headers that were not configured, including:

- Content-Security-Policy
- Strict-Transport-Security
- Referrer-Policy
- Permissions-Policy

Risk Level: Medium

Impact

Missing security headers reduce browser-based protections and may increase the risk of attacks such as Cross-Site Scripting (XSS), clickjacking, and information leakage.

Finding 3 – Publicly Accessible Resources

Nikto discovered several publicly accessible resources including:

- robots.txt
- /ftp/
- /public/
- JSON files
- .htpasswd
- .bash_history

Risk Level: Medium

Impact

Publicly accessible files may reveal sensitive information, disclose application structure, or provide useful information to attackers during reconnaissance.

Finding 4 – API Endpoint Discovery

Dirsearch identified multiple API endpoints including:

- /api
- /api-docs
- /assets
- Additional API documentation paths

Risk Level: Medium

Impact

Publicly accessible API documentation and endpoints increase the visibility of application functionality and may assist attackers in identifying potential vulnerabilities.

Risk Ratings

Finding	Risk Level
Exposed Web Service (Port 3000)	Medium
Missing Security Headers	Medium
Publicly Accessible Resources	Medium
Exposed API Endpoints	Medium
OWASP Juice Shop Identification	Informational

Overall Risk Rating:

Medium

The overall risk is considered Medium because the target intentionally exposes several security weaknesses for educational purposes. In a production environment, these findings should be remediated before deployment.

Impact Analysis

The assessment demonstrates that although the target application is functioning correctly, several security weaknesses increase its overall attack surface. Missing browser security headers reduce protection against common client-side attacks, while publicly accessible directories and API endpoints provide additional information that could be leveraged during further reconnaissance.

Although these findings are expected within OWASP Juice Shop, similar issues in production environments could lead to information disclosure, unauthorized access, session attacks, or exploitation of application vulnerabilities

Recommendations

The following remediation measures are recommended:

1. Configure Content-Security-Policy (CSP) to reduce Cross-Site Scripting attacks.
2. Enable HTTP Strict Transport Security (HSTS) to enforce encrypted communication.
3. Configure Referrer-Policy and Permissions-Policy headers.
4. Remove or restrict unnecessary public directories and sensitive files.
5. Secure API endpoints through proper authentication and authorization.
6. Disable unnecessary services exposed to the network.
7. Keep the operating system and web application updated with the latest security patches.
8. Perform periodic vulnerability assessments and penetration testing to identify newly introduced weaknesses.
9. Follow the Principle of Least Privilege for users, services, and application components.

Evidence

The following evidence was collected during the assessment:

Scan Reports

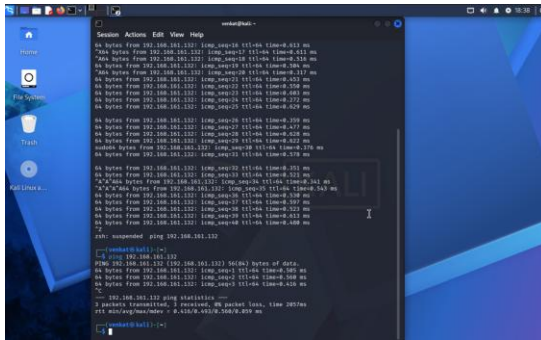
- nmap_basic.txt
- nmap_service.txt
- aggressive_scan.txt
- nikto_report.txt
- Dirsearch.txt

Txt files word document link:

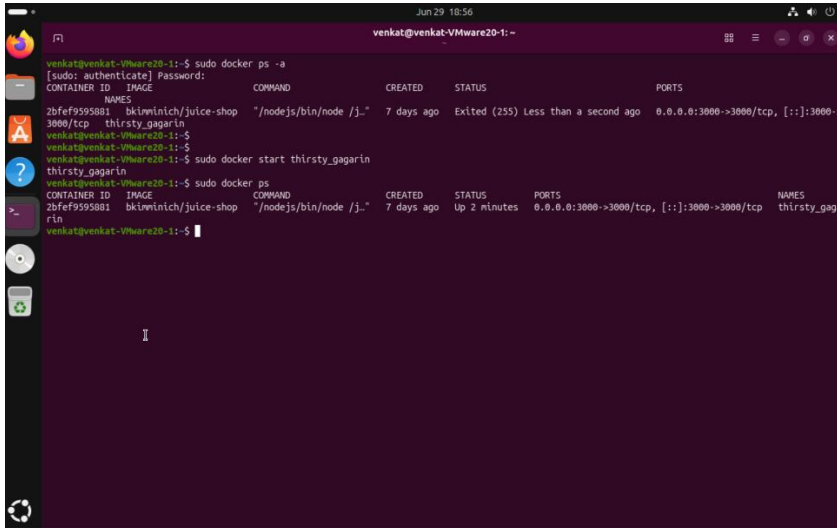
[TXT_files_evidence_task3.docx](#)

Screenshots

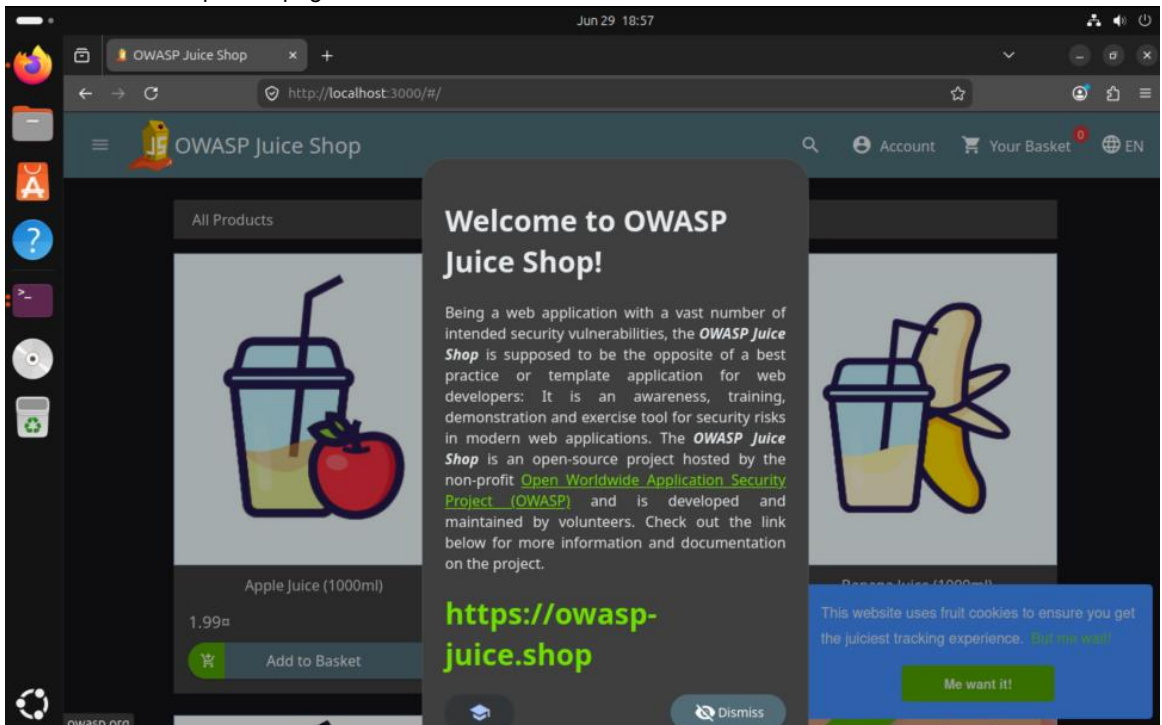
- Successful Ping Test



- Docker Container running



- OWASP Juice shop homepage:



- Nmap Basic Scan:

```
(venkat@kali)-[~]
$ nmap 192.168.161.132
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-29 20:11 +0530
Nmap scan report for 192.168.161.132
Host is up (0.00096s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
3000/tcp  open  ppp
MAC Address: 00:0C:29:3F:C8:3B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.69 seconds +0530
(venkat@kali)-[~]
$
```

- Nmap Service Detection Scan:


```
venkat@kali: ~  
Session Actions Edit View Help  
venkat@kali)-[~]  
$ nmap -sC -sV 192.168.161.132  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-29 20:23 +0530  
Nmap scan report for 192.168.161.132  
Host is up (0.00086s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
3000/tcp  open  ppp?  
| fingerprint-strings:  
|   GetRequest:  
|     HTTP/1.1 200 OK  
|     Access-Control-Allow-Origin: *  
|     X-Content-Type-Options: nosniff  
|     X-Frame-Options: SAMEORIGIN  
|     Feature-Policy: payment 'self'  
|     X-Recruiting: /#/jobs  
|     Accept-Ranges: bytes  
|     Cache-Control: public, max-age=0  
|     Last-Modified: Mon, 29 Jun 2026 13:23:10 GMT  
|     ETag: W/"26af-19f138c4ffb"  
|     Content-Type: text/html; charset=UTF-8  
|     Content-Length: 9903  
|     Vary: Accept-Encoding  
|     Date: Mon, 29 Jun 2026 14:06:42 GMT  
|     Connection: close  
|     <!--  
|     Copyright (c) 2014-2026 Bjoern Kimminich, the OWASP Juice Shop contributors.  
|     SPDX-License-Identifier: MIT  
|     <!doctype html>  
|     <html lang="en" data-beasties-container>  
|     <head>  
|     <meta charset="utf-8">  
|     <title>OWASP Juice Shop</title>  
|     <meta name="description" content="Probably the most modern and sophisticated inse  
cure web application">  
|     <meta name="viewport" content="width=device-width, initial-scale=1">  
|     <link rel="preconnect" href="htt  
|     HTTPOptions, RTSPRequest:  
|     HTTP/1.1 204 No Content  
|     Access-Control-Allow-Origin: *  
|     Access-Control-Allow-Methods: GET,HEAD,PUT,PATCH,POST,DELETE  
|     Vary: Access-Control-Request-Headers  
|     Content-Length: 0  
|     Date: Mon, 29 Jun 2026 14:06:42 GMT  
|     Connection: close  
|     Help, NCP:  
|     HTTP/1.1 400 Bad Request  
|     Connection: close  
_ service unrecognized despite returning data. If you know the service/version, please  
submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :  
SF-Port3000-TCP-V=7.98I=7%D=6/29%Time=6A428701P=aarch64-unknown-linux-gn
```

- Nikto Scan Results:

```
venkat@kali: ~/Task3
Session Actions Edit View Help
(venkat@kali)~$ nikto -h http://192.168.161.132:3000
- Nikto v2.6.0

+ Target IP: 192.168.161.132
+ Target Hostname: 192.168.161.132
+ Target Port: 3000
+ Platform: Unknown
+ Start Time: 2026-06-29 20:39:01 (GMT5.5)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [001675] /ftp/: This might be interesting.
+ [001811] /public/: This might be interesting.
+ [002739] /.htpasswd: Contains authorization information.
+ [002743] /.bash_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [002756] /.sh_history: A user's home directory may be set to the web root, the shell history was retrieved. This should not be accessible via the web.
+ [007203] /userdata.json: This might be interesting.
+ ERROR: *** Error limit (20) reached for host, giving up. Last error: opening stream: can't connect (timeout): Transport endpoint is not connected. ***
+ ERROR: *** Consider using mitmproxy to avoid TLS fingerprinting. ***
- STATUS: Completed 8459 requests: currently in plugin 'Nikto Tests'
- STATUS: Running average: Not enough data.
+ Scan terminated: 20 errors and 13 items reported on the remote host
+ End Time: 2026-06-29 20:40:06 (GMT5.5) (65 seconds)

+ 1 host(s) tested
```

- Dirsearch Results:

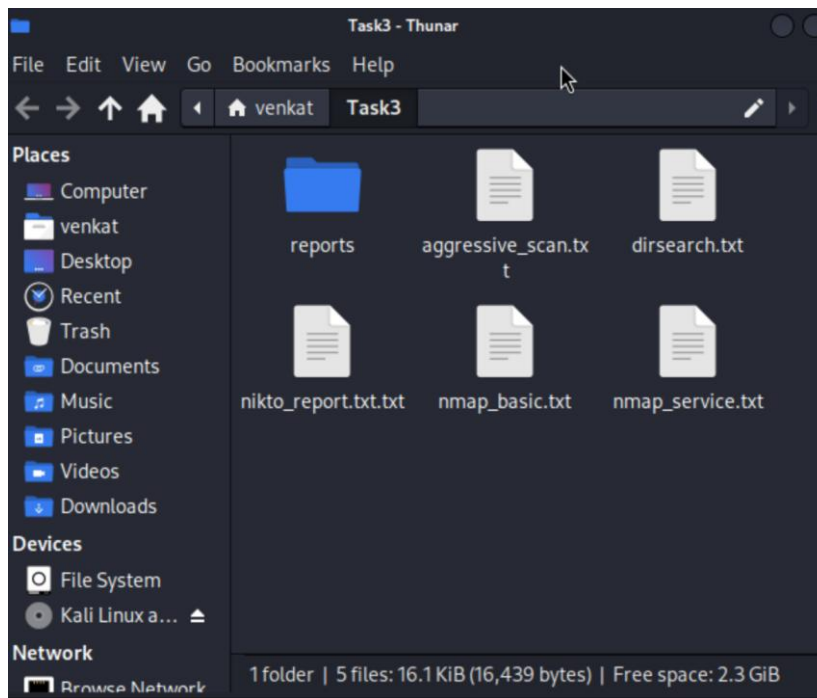
```
venkat@kali: ~/Task3
Session Actions Edit View Help

-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/controller/controller.py", line 482
, in raise_error
    raise SkipTargetInterrupt("Too many request errors")
File "/usr/lib/python3.13/threading.py", line 995, in run
    self._target(*self._args, **self._kwargs)
-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/core/fuzzer.py", line 268, in thread_proc
    callback(e)
-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/controller/controller.py", line 482
, in raise_error
    raise SkipTargetInterrupt("Too many request errors")
lib.core.exceptions.SkipTargetInterrupt: Too many request errors
File "/usr/lib/python3.13/threading.py", line 995, in run
    self._target(*self._args, **self._kwargs)
-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/core/fuzzer.py", line 268, in thread_proc
    callback(e)
-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/controller/controller.py", line 482
, in raise_error
    raise SkipTargetInterrupt("Too many request errors")
lib.core.exceptions.SkipTargetInterrupt: Too many request errors
lib.core.exceptions.SkipTargetInterrupt: Too many request errors
File "/usr/lib/python3.13/threading.py", line 995, in run
    self._target(*self._args, **self._kwargs)
-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/core/fuzzer.py", line 268, in thread_proc
    callback(e)
-----
File "/usr/lib/python3/dist-packages/dirsearch/lib/controller/controller.py", line 482
, in raise_error
    raise SkipTargetInterrupt("Too many request errors")
lib.core.exceptions.SkipTargetInterrupt: Too many request errors

Task Completed

(venkat@kali)~$
```

- Evidence Folder Contents:



Conclusion

This vulnerability assessment successfully demonstrated the complete workflow followed by cybersecurity professionals when performing an initial security evaluation of a web application. Using Nmap, Nikto, and Dirsearch, the assessment identified an exposed web service, enumerated available services, discovered accessible resources, and documented several common web application security weaknesses.

No exploitation was performed, keeping the assessment within the defined scope of a non-destructive vulnerability assessment. The findings and recommendations documented in this report provide a strong foundation for improving application security and serve as a baseline for future penetration testing activities.

Overall, the objectives of the assessment were successfully achieved, and the exercise provided valuable practical experience in vulnerability identification, documentation, risk assessment, and professional reporting.